

TECHNICAL AUDIT & IMPROVEMENT REPORT

Trade Pilot App

Flutter mobile client — audit menyeluruh kode, keamanan, kesiapan rilis store, dan rekomendasi roadmap.

Repository	tradepilotapp
Branch	feat/flutter-app
Commit	8c43038
Versi app	1.0.1+3
Tanggal audit	6 September 2026
Cakupan	77 file Dart · ~26.900 baris

Report ini dibuat dari pembacaan kode sumber langsung, eksekusi `flutter analyze`, `flutter test --coverage`, `flutter pub outdated`, serta pemeriksaan konfigurasi build Android/iOS dan riwayat Git. Setiap temuan disertai lokasi file, alasan, dan langkah perbaikan konkret.

1 • Ringkasan Eksekutif

Kesimpulan singkat: **project ini sehat dan jauh di atas rata-rata** untuk app Flutter seukuran ini. Arsitekturnya rapi, testnya jalan, lintnya bersih. Yang menahannya bukan kualitas kode — tapi **satu lubang keamanan di alur login**, beberapa item kesiapan store, dan tidak adanya infrastruktur operasional (CI, crash reporting).

0

ISSUE ANALYZE

151

TEST LULUS

47,9%

COVERAGE

26.909

BARIS DART

21

TEMUAN

Health card per aspek

ASPEK	NILAI	CATATAN
Arsitektur & state management	A-	Provider + repository, isolasi cache antar-user, request-id/epoch guard, cancel token. Ini pola yang biasanya cuma ada di tim senior.
Kualitas kode & lint	A	<code>flutter analyze</code> bersih total. Nol TODO/FIXME. Nol <code>print()</code> liar.
Localization (ARB)	A	355 key, EN/ID lengkap dan seimbang — tidak ada key yang bolong.
Testing	B-	151 test lulus, tapi 4 tab utama coverage-nya ~0,2%.
Performance & lifecycle	B	<code>HomeShell</code> menangani lifecycle dengan benar; detail screen belum.
Kepatuhan konten finansial	A	8 disclaimer berbeda tersebar di ARB. Ini sering jadi alasan penolakan Play Store — dan sudah aman.
Keamanan	C-	Password mentah disimpan di device untuk fitur "Remember me". Ini yang paling mendesak.
Kesiapan store (iOS/Android)	C+	Privacy manifest iOS hilang, backup Android terbuka, tidak ada adaptive icon, R8 mati.
Internasionalisasi aktual	C+	Infrastruktur A, tapi ~129 string masih hardcoded Bahasa Indonesia di luar ARB.
Observability	F	Nol crash reporting, nol analytics. Kalau app crash di HP user, lo tidak akan pernah tahu.
CI/CD	F	Tidak ada workflow sama sekali. Semua verifikasi manual.
Dokumentasi	C	README basi — masih mendaftar fitur "belum dibuat" yang sebenarnya sudah selesai.

Prioritas dalam satu tarikan napas

- Berhenti menyimpan password user di device** — ganti ke session-token yang digerbangi biometrik. (P0-1)
- Matikan Android Auto Backup** — satu baris di manifest, mencegah kredensial terenkripsi ikut tercadang ke cloud. (P0-2)
- Tambah `PrivacyInfo.xcprivacy`** — App Store bisa menolak submission tanpa ini. (P0-3)
- Pasang interceptor 401 terpusat** — sekarang token kedaluwarsa bikin user terjebak di layar error. (P0-4)

5. **Pasang Sentry + GitHub Actions** — dua sore kerja, langsung mengubah cara lo maintain app ini selamanya. (P1-5, P1-6)

Yang sudah bagus dan jangan diubah. Pola `_sessionEpoch` + `_requestId` di `AnalysisProvider` untuk mencegah respons dari sesi lama menimpa state sesi baru — itu benar dan jarang orang ingat. Timeout `receiveTimeout: 150s` khusus endpoint AI dengan komentar alasannya. Lifecycle handling di `HomeShell` yang mematikan SSE dan polling saat app ke background. Ini semua keputusan yang matang.

2 · Prioritas 0 — Wajib sebelum rilis berikutnya

P0-1 Password mentah user disimpan permanen di device

lib/screens/auth/login_screen.dart:24–25, 63–70, 74–88, 111–126

Fitur "Remember me" menyimpan *password asli* user ke `flutter_secure_storage` dengan key `remembered_login_password`. Saat app dibuka, `_restoreRememberedCredentials()` menulis password itu balik ke `TextEditingController` milik form. Login biometrik (`_loginWithBiometrics`) tidak melakukan autentikasi mandiri — dia cuma memicu `_submit()` yang mengirim password tersimpan itu.

Tiga konsekuensi nyata:

- **Password tidak bisa dicabut.** Session token bisa lo-invalidate dari server kapan saja. Password tidak — begitu bocor, dia membuka akun web Trade Pilot juga, dan kemungkinan besar akun lain milik user yang pakai password sama.
- **Terlihat mata telanjang.** Password sudah terisi di field saat app dibuka. Siapa pun yang pegang HP dalam keadaan tidak terkunci tinggal menekan ikon mata untuk membacanya.
- **Biometrik jadi teater.** Face ID di sini hanya membuka gerbang ke password yang toh sudah tersimpan — bukan pengganti kredensial. Nilai keamanannya nol dibanding tombol login biasa.

Perbaikan. Jangan pernah persist password. Alurnya: setelah login sukses, token sesi sudah tersimpan di `TokenStorage` — cukup tandai `biometric_enabled=true`. Di layar login, kalau flag itu ada, tampilkan tombol biometrik; setelah `authenticate()` berhasil, baca token yang sudah ada dan panggil `getMe()` untuk memulihkan sesi. Simpan email saja untuk prefill (itu tidak sensitif). Hapus `_rememberedPasswordKey` sepenuhnya, dan tambahkan migrasi sekali-jalan yang meng- `delete` key lama supaya password yang sudah terlanjur tersimpan di HP user existing ikut terhapus saat update.

P0-2 Android Auto Backup aktif — kredensial ikut tercadang

android/app/src/main/AndroidManifest.xml

Tag `<application>` tidak menyetel `android:allowBackup`, jadi Android memakai default `true`. Artinya isi `EncryptedSharedPreferences` — tempat token sesi dan (untuk saat ini) password tersimpan — masuk ke Google Drive backup user. Selain risiko keamanan, ini juga penyebab umum bug "app crash setelah restore ke HP baru": blob terenkripsi ikut ter-restore tapi kunci Keystore-nya tidak, sehingga `flutter_secure_storage` gagal mendekripsi dan melempar exception saat startup.

Perbaikan. Tambahkan atribut pada `<application>` :

```
android:allowBackup="false"
android:fullBackupContent="false"
android:dataExtractionRules="@xml/data_extraction_rules"
```

Kalau nanti lo mau backup tetap jalan untuk preferensi non-sensitif, pakai `data_extraction_rules.xml` dengan `<exclude>` untuk shared-prefs milik secure storage.

P0-3 iOS Privacy Manifest tidak ada

`ios/Runner/` – tidak ditemukan `PrivacyInfo.xcprivacy`

Apple mewajibkan privacy manifest untuk app yang memakai "required reason API". App ini memakai `shared_preferences` (UserDefaults — kategori `CA92.1`), `flutter_secure_storage` (Keychain), `image_picker`, dan `local_auth`. Tanpa manifest, App Store Connect mengirim email peringatan dan pada kasus tertentu menolak build. Ini murni masalah administratif tapi bisa menahan rilis sehari-hari di saat yang paling tidak enak.

Perbaikan. Buat `ios/Runner/PrivacyInfo.xcprivacy`, tambahkan ke target Runner di Xcode, isi `NSPrivacyAccessedAPITypes` untuk UserDefaults dengan reason `CA92.1`, dan set `NSPrivacyTracking=false` dengan `NSPrivacyCollectedDataTypes` yang jujur (email & user ID, untuk fungsionalitas app, tertaut ke identitas, bukan untuk tracking). Sekalian upgrade `flutter_secure_storage` ke v11 (lihat P1-9) — versi 9.x belum membawa manifest sendiri.

P0-4 Tidak ada penanganan 401 terpusat — sesi kedaluwarsa bikin user terjebak

`lib/providers/*.dart` (8 lokasi terpisah) · `packages/trade_pilot_api_client/lib/trade_pilot_client.dart`

Delapan tempat berbeda menerjemahkan status 401 jadi pesan "*Sesi login sudah berakhir*", tapi **tidak ada satu pun yang benar-benar menutup sesi**. `AuthProvider.status` tetap `authenticated`, token mati tetap tersimpan, dan setiap request berikutnya gagal lagi dengan pesan yang sama. Satu-satunya jalan keluar user adalah logout manual — dan banyak yang akan memilih uninstall.

`_restoreSession()` memang membersihkan token invalid, tapi itu hanya berjalan sekali saat app start. Token yang mati *di tengah* sesi tidak tertangani sama sekali.

Perbaikan. Tambahkan satu interceptor di `TradePilotClient` — dia sudah punya seam-nya (`Dio` get `dio` plus komentar yang mengundang interceptor tambahan). Pada `onError`, kalau `statusCode == 401` dan path bukan endpoint login/register, panggil callback `onUnauthorized` yang di-inject `AuthProvider`; callback itu menjalankan `logout()` lokal (tanpa memanggil API logout, token sudah mati) lalu `notifyListeners()`. Splash/root widget yang sudah memantau `AuthStatus` akan otomatis mengembalikan user ke layar login. Setelah itu hapus 8 penanganan 401 duplikat di provider — cukup sisakan pesan untuk kasus 401 yang memang bermakna beda, yaitu "password saat ini salah" di `changePassword` dan `deleteAccount`.

3 · Prioritas 1 — Penting, kerjakan dalam 30 hari

P1-5 Nol crash reporting — lo buta terhadap kondisi produksi

seluruh project

Tidak ada Sentry, Crashlytics, atau error tracker apa pun. App sudah rilis (versi 1.0.1+3, ada `in_app_update` dan `upgrader`), yang berarti sudah ada user asli — dan kalau ada yang crash, satu-satunya sinyal yang lo dapat adalah rating bintang satu tanpa penjelasan. Banyak `catch (_) {}` senyap di seluruh provider: secara UX itu benar (jangan ganggu user untuk kegagalan non-kritis), tapi tanpa reporter, error itu hilang total.

Perbaikan. Pasang `sentry_flutter` — pilihan paling ringan karena tidak menyeret Firebase kembali masuk (yang baru saja lo copot di commit 526af49). Bungkus `runApp` dengan `SentryFlutter.init`, set `tracesSampleRate` kecil, dan yang paling berdampak: ubah `catch (_) {}` yang senyap jadi `catch (e, s) { Sentry.captureException(e, stackTrace: s); }` sambil tetap tidak menampilkan apa-apa ke user. Set juga `beforeSend` untuk membuang header `Authorization` dari breadcrumb.

P1-6 Tidak ada CI — kualitas bergantung pada disiplin manual

`.github/` — hanya berisi artefak tool "modernize", nol workflow

Saat ini `analyze` bersih dan 151 test lulus, tapi itu karena lo menjalankannya sendiri. Tidak ada yang mencegah commit berikutnya merusaknya tanpa ketahuan.

Perbaikan. Satu file `.github/workflows/ci.yml` sudah cukup jauh: `flutter pub get` → `dart format --set-exit-if-changed` → `flutter analyze --fatal-infos` → `flutter test --coverage`, jalan di setiap push dan PR. Tambahkan job kedua yang menjalankan `flutter build appbundle` supaya kegagalan build Android ketahuan sebelum hari rilis. Signing key jangan masuk CI dulu — cukup `--no-shrink` build unsigned untuk verifikasi kompilasi.

P1-7 ±129 string Bahasa Indonesia hardcoded — user berbahasa Inggris melihat teks Indonesia

lib/providers/ (50 string) · lib/screens/ & lib/widgets/ (79 string)

Ini ironis: infrastruktur I10n lo *sempurna* — 355 key, EN dan ID sama persis jumlahnya, tidak ada satu pun yang bolong, dan hanya 2 string yang identik antar-bahasa (itu pun memang seharusnya sama). Tapi banyak teks tidak pernah masuk ARB sama sekali:

LOKASI	JUMLAH	CONTOH
screens/journal/trade_journal_screen.dart	30	"Hapus entri jurnal?", "Masih terbuka", "Impas"
screens/analysis/analysis_detail_screen.dart	12	—
screens/daily_summary/daily_summary_screen.dart	9	—
screens/analytics/ , trader_mirror/	10	—
Sisa screens & widgets	18	—
Semua pesan error di provider	50	"Sesi login sudah berakhir.", "Gagal memuat price alert."

Yang 50 di provider adalah yang paling menyakitkan, karena pesan error justru muncul di momen user paling frustrasi — dan mereka menerimanya dalam bahasa yang tidak mereka pilih.

Perbaikan. Untuk screens: pindahkan langsung ke ARB, pekerjaan mekanis. Untuk provider, jangan simpan `String` — provider tidak punya `BuildContext` dan memang tidak seharusnya tahu soal bahasa. Ganti field `errorMessage` jadi enum atau sealed class (`AppError.sessionExpired`, `AppError.network`, `AppError.quotaExceeded`, `AppError.server(String raw)`), lalu petakan enum → teks di layer widget yang punya akses `context.l10n`. Ini juga bikin test provider lebih kuat: `assert` enum, bukan mencocokkan kalimat.

P1-8 Cached user disimpan tapi tidak pernah dibaca — cold start offline melempar user ke login

lib/core/storage/token_storage.dart:27–35 · lib/providers/auth_provider.dart:43–62

`TokenStorage.saveUser()` dan `readUserMap()` tidak dipanggil dari mana pun di `lib/` maupun `test/` — keduanya kode mati. Konsekuensinya: `_restoreSession()` selalu butuh round-trip `getMe()` yang sukses. Kalau user membuka app dalam kondisi sinyal jelek atau server sedang down, `catch` memperlakukan itu sama dengan token invalid: storage dibersihkan, user dilempar ke layar login — *dan token yang sebenarnya masih sah ikut terhapus*, jadi mereka harus mengetik ulang kredensial.

Perbaikan. Dua hal. Pertama, bedakan jenis kegagalan di `_restoreSession()`: hanya bersihkan sesi kalau `DioException` membawa `statusCode == 401`. Untuk `connectionError /timeout`, pertahankan token. Kedua, pakai cache yang sudah lo tulis: panggil `saveUser()` di `_applyAuthResponse` dan `refreshMe`, lalu di `_restoreSession()` hidrasi user dari `readUserMap()` lebih dulu dan set status `authenticated` secara optimistik, baru revalidasi via `getMe()` di latar. App langsung terbuka, tidak ada layar putih.

P1-9 Dependency tertinggal, satu di antaranya sudah discontinued

pubspec.yaml · pubspec.lock

PAKET	SEKARANG	TERBARU	KENAPA PENTING
flutter_secure_storage	9.2.4	11.0.0	Transitif flutter_secure_storage_macos berstatus discontinued . v11 pindah ke _darwin dan membawa privacy manifest (relevan ke P0-3).
fl_chart	0.69.2	1.2.0	Lompat ke 1.x — ada breaking change, tapi lo sedang di pre-1.0 untuk komponen yang jadi jantung tampilan analisis.
in_app_update	4.2.5	5.0.0	Menyentuh Play Core; versi lama berisiko bermasalah dengan target SDK baru.
dio	5.11.0	5.11.1	Patch, aman langsung.
intl	0.20.2	0.20.3	Patch, aman langsung.

Perbaikan. Kerjakan bertahap, bukan sekaligus. Ronde 1 (hari ini): flutter pub upgrade untuk yang patch-level. Ronde 2: flutter_secure_storage ke v11 — ini yang paling berdampak dan perlu tes ulang di device fisik iOS & Android karena menyentuh Keychain/Keystore. Ronde 3: fl_chart 1.x, sisihkan waktu untuk membaca changelog dan perbaiki chart satu per satu.

P1-10 Push notification hilang total — tapi UI-nya masih menjanjikan

lib/providers/notifications_provider.dart:322, 426, 495, 541 · docs/WEB_TEAM_HANDOFF_NATIVE_PUSH_*.md

Firebase dicopot di commit 526af49 dan belum ada penggantinya. Yang tersisa hanyalah SSE (/notifications/stream) yang sengaja dimatikan saat app ke background — keputusan yang benar secara teknis. Tapi UI preferensi push masih memanggil getPushPrefs() dan updatePushPrefs(), jadi user masih bisa mengatur notifikasi yang **tidak akan pernah sampai** ketika app tertutup.

Untuk app trading, ini bukan sekadar fitur kurang — ini merusak proposisi nilai intinya. Price alert yang cuma berbunyi saat app terbuka bukan alert; itu cuma indikator.

Perbaikan — pilih satu. Kalau lo mau push beneran, jalur paling pendek adalah masuk lagi ke FCM (Android) + APNs via FCM (iOS) dengan firebase_messaging saja — tanpa Analytics/Crashlytics, supaya ukuran app tidak melar. Backend perlu endpoint registrasi device token; dokumen handoff di docs/ sudah menyiapkan kontraknya. Kalau belum siap, **minimal sembunyikan dulu toggle preferensi push-nya** di build ini — lebih baik fitur tidak ada daripada ada tapi bohong.

P1-11 R8/minify mati di release build Android

android/app/build.gradle.kts – blok `release` hanya menyetel `signingConfig`

Tanpa `isMinifyEnabled` dan `isShrinkResources`, AAB lo lebih besar dari yang seharusnya dan kode Kotlin/Java-nya bisa dibaca langsung oleh siapa pun yang mengunduh dari Play. Untuk app finansial, minimal naikan biaya reverse-engineering.

Perbaikan. Di blok `release` :

```
isMinifyEnabled = true
isShrinkResources = true
proguardFiles(
    getDefaultProguardFile("proguard-android-optimize.txt"),
    "proguard-rules.pro"
)
```

Wajib diuji dengan build release asli, bukan debug — dan siapkan `-keep rules` untuk `local_auth` dan Play Core kalau ada `ClassNotFoundException`. Sekalian aktifkan `--obfuscate --split-debug-info` di perintah build Flutter, lalu simpan symbol-nya untuk membaca stack trace Sentry (P1-5).

P1-12 Tidak ada adaptive icon Android

android/app/src/main/res/ – tidak ada `mipmap-anydpi-v26`

Cuma ada `ic_launcher.png` di lima `mipmap density`. Di Android 8 ke atas (yaitu praktis semua HP aktif), launcher akan memaksa ikon PNG lo masuk ke bentuk sistem — hasilnya ikon kelihatan kotak, kekecilan, atau ter-crop di tengah sementara app lain di sekitarnya mulus. Untuk app yang branding-nya rapi (hitam+emas), ini terlihat murah di layar utama.

Perbaikan. Buat `mipmap-anydpi-v26/ic_launcher.xml` dengan `<adaptive-icon>` : background solid warna brand, foreground logo dengan safe-zone 66% (logo harus muat dalam lingkaran tengah). Cara paling cepat: pakai `flutter_launcher_icons` di `dev_dependencies` dengan `adaptive_icon_background` + `adaptive_icon_foreground`, lalu sekalian generate `monochrome` untuk themed icon Android 13.

4 · Prioritas 2 — Kualitas & maintainability

P2-13 File raksasa: `analysis_detail_screen.dart` 2.778 baris

`lib/screens/analysis/analysis_detail_screen.dart` · `dashboard_tab.dart` (1.434) · `analyze_tab.dart` (1.298) · `history_tab.dart` (1.160)

Kabar baiknya: isinya *tidak* berantakan. File itu sudah terpecah jadi ~15 widget privat yang bersih (`_HeaderCard` , `_RiskCard` , `_OutcomeCard` , `_TechnicalIndicatorsCard` , dan seterusnya). Masalahnya murni bahwa semuanya tinggal di satu file — yang bikin navigasi lambat, diff sulit dibaca saat review, dan konflik merge lebih sering kalau nanti ada orang kedua di repo ini.

Perbaikan. Ini refactor paling murah yang bisa lo lakukan karena strukturnya sudah benar: bikin `lib/screens/analysis/widgets/` , pindahkan setiap `_Xxx` ke file sendiri, ubah jadi publik. Nol perubahan logika, nol risiko. Prioritaskan file di atas 800 baris saja; sisanya biarkan.

P2-14 Coverage 47,9% — tapi seluruh alur utama nyaris tidak tersentuh

`coverage/lcov.info`

Angka agregat menipu. Sebaran per-file jauh lebih informatif:

FILE	COVERAGE	BARIS
<code>screens/home/tabs/analyze_tab.dart</code>	0,2%	505
<code>screens/home/tabs/history_tab.dart</code>	0,2%	518
<code>screens/home/tabs/dashboard_tab.dart</code>	0,2%	565
<code>screens/notifications/notifications_screen.dart</code>	0,4%	284
<code>screens/home/home_shell.dart</code>	0,8%	124
<code>widgets/price_alert/price_alert_sheet.dart</code>	0,0%	112
<code>providers/notifications_provider.dart</code>	25,8%	267
<code>providers/analysis_provider.dart</code>	49,2%	472
<code>core/</code> engines (market, mindset, statistics)	80–100%	—

Polanya jelas: logika murni diuji dengan baik, UI dan orkestrasi tidak. Itu urutan prioritas yang wajar untuk tahap awal — tapi empat tab utama adalah 1.700 baris yang dilihat setiap user setiap hari, dan tidak ada satu pun test yang akan berteriak kalau salah satunya rusak.

Perbaikan. Jangan kejar persentase. Tulis satu widget test "smoke" per tab yang cuma memastikan: tab render tanpa exception dengan provider ter-mock di tiga kondisi — loading, ada data, error. Lima test seperti itu menangkap mayoritas regresi nyata dan bisa lo tulis dalam satu sore. Tambahkan juga test untuk `notifications_provider` di jalur SSE reconnect, karena itu bagian paling rumit yang coverage-nya paling tipis.

P2-15 Polling 10 detik di detail screen tetap jalan saat app di background

lib/screens/analysis/analysis_detail_screen.dart:121–128

`_startOutcomePolling()` memasang `Timer.periodic(10s)` yang memanggil `_load(silent: true)` selama `outcomeStatus` masih `pending`. Berbeda dengan `HomeShell`, screen ini tidak memakai `WidgetsBindingObserver` — jadi kalau user membuka detail analisis lalu pindah app, timer terus menembak server tiap 10 detik sampai screen di-dispose. Baterai dan kuota data user yang membayarnya, dan server lo yang menerima trafik sia-sia.

Perbaikan. Tambahkan `with WidgetsBindingObserver` pada `_AnalysisDetailScreenState`, hentikan timer di `paused / inactive` dan mulai lagi di `resumed` — persis pola yang sudah lo pakai di `HomeShell`. Sekalian tambahkan batas: berhenti polling otomatis setelah misalnya 5 menit, karena outcome yang belum resolve dalam 5 menit kemungkinan besar masih akan pending lama.

P2-16 README sudah usang dan menyesatkan

README.md

Bagian "Belum diimplementasikan" masih mendaftar Analytics, Trade Journal, Trader Mirror, Daily Summary, My Alerts, dan Mindset sebagai fitur yang belum dibuat — padahal keenamnya sudah ada file screen-nya dan sudah di-commit. README juga masih bilang "*belum pernah di-compile atau di-flutter analyze*", sementara kenyataannya `analyze` bersih dan 151 test lulus. Buat orang baru (atau buat lo sendiri tiga bulan lagi), dokumen ini aktif menyesatkan.

Perbaikan. Tulis ulang: status fitur yang jujur, perintah build per environment (`--dart-define`), cara rilis ke Play/App Store, dan catatan bahwa `packages/trade_pilot_api_client` di-vendor manual dari repo Trade-Pilot. Tambahkan juga `CLAUDE.md` ringkas berisi konvensi repo — pola provider, aturan l10n, di mana menaruh widget baru — supaya bantuan AI ke depan konsisten dengan gaya kode lo, bukan menebak.

P2-17 Navigasi imperatif — deep link akan sulit ketika push masuk

27 pemakaian `Navigator.push / MaterialPageRoute` · `lib/main.dart` tanpa `routes / onGenerateRoute`

Untuk app sebesar ini, `Navigator 1.0` masih bisa dipertahankan. Tapi begitu push notification masuk (P1-10), lo butuh kemampuan membuka `analisis #482` langsung dari notifikasi, dari kondisi app terminated, dengan back-stack yang masuk akal. Itu berantakan kalau dikerjakan manual. Model `notification_action.dart` yang sudah ada mengisyaratkan lo memang berencana ke sana.

Perbaikan. Kalau push jadi dikerjakan, migrasi ke `go_router` lebih dulu — bukan sesudahnya. Definisikan path bernama (`/analysis/:id`, `/alerts`, `/journal`), pasang `redirect` berbasis `AuthStatus` untuk menggantikan pengecekan auth manual, dan deep link jadi hampir gratis. Kalau push ditunda, ini bisa ditunda juga.

P2-18 Aksesibilitas nyaris tidak digarap

7 pemakaian `Semantics` / `semanticLabel` di 26.909 baris

Banyak informasi di app ini disampaikan lewat warna dan bentuk saja: confidence bar, badge bias bullish/bearish, chip indikator teknikal, mini chart. Buat pengguna screen reader, sebagian besar itu terbaca sebagai elemen kosong. Untuk app finansial di Indonesia ini belum jadi kewajiban hukum, tapi Apple sudah mulai menyorotinya di review, dan ini juga soal jumlah user yang bisa lo layani.

Perbaikan. Fokus di tiga tempat dengan dampak terbesar: bungkus confidence bar dengan `Semantics(label: 'Tingkat keyakinan 72 persen', value: ...)`, beri `semanticLabel` pada badge bias, dan beri ringkasan teks pada chart (`Semantics(label: 'Grafik harga XAU/USD 24 jam terakhir, naik 1,2 persen')`). Sekalian cek kontras warna emas-di-hitam dengan rasio 4.5:1 — brand gelap sering gagal di sana.

P2-19 Beda antara namespace dan applicationId Android

`android/app/build.gradle.kts:33, 45`

`namespace = "com.tradepilot.app"` tapi `applicationId = "id.tradepilot.app"`. Ini secara teknis sah dan app jalan normal — `applicationId` yang menentukan identitas di Play Store. Tapi `namespace` menentukan package `BuildConfig` dan `R`, jadi setiap kali lo atau kontributor lain menulis kode native atau mencari log, ada dua string yang bersaing di kepala. `applicationId` **tidak boleh diubah** karena app sudah rilis.

Perbaikan. Samakan `namespace` jadi `id.tradepilot.app`, pindahkan `MainActivity.kt` ke direktori yang cocok, dan biarkan `applicationId` apa adanya. Perubahan aman, tidak mempengaruhi update untuk user existing.

P2-20 Tidak ada deteksi konektivitas maupun retry berjenjang

seluruh layer network

Setiap kegagalan jaringan berakhir jadi pesan statis "Tidak bisa terhubung ke server". Tidak ada perbedaan antara *HP lagi offline* dan *server lagi down*, dan tidak ada retry otomatis ketika koneksi pulih — user harus menarik-refresh sendiri. Satu-satunya retry yang ada adalah `_scheduleTimeoutRevalidation` di `AnalysisProvider`, yang bagus tapi hanya untuk kasus timeout pembuatan analisis.

Perbaikan. Tambahkan `connectivity_plus`, tampilkan banner offline persisten di `HomeShell`, dan picu `refreshCoreData(silent: true)` otomatis saat koneksi kembali. Untuk request idempoten (semua GET), pasang interceptor retry dengan exponential backoff — 3 percobaan, jangan sentuh POST/PATCH/DELETE.

P2-21 Sampah di working tree

firebase-debug.log (90 KB) · .DS_Store · tmp/ · output/.DS_Store

Semuanya untung tidak ter-*track* Git (`git status` bersih), jadi ini murni kebersihan lokal. `firebase-debug.log` adalah sisa dari integrasi Firebase yang sudah dicopot dan tidak berguna lagi. `.gitignore` juga belum menutup `/output/` dan `/tmp/`.

Perbaikan. Hapus `firebase-debug.log` dan `tmp/`, lalu tambahkan `firebase-debug.log`, `/tmp/`, dan `**/.DS_Store` ke `.gitignore`. Catatan: `output/play-console/trade_pilot_app_icon_512.png` memang ter-track dan itu wajar — aset store layak disimpan.

5 • Saran strategis untuk Trade Pilot

Bagian ini bukan soal bug. Ini soal ke mana app-nya sebaiknya dibawa, berdasarkan apa yang sudah lo bangun.

Yang paling membedakan app ini dari kompetitor

Yang menarik dari codebase ini bukan fitur analisisnya — itu bisa ditiru. Yang susah ditiru adalah `lib/core/` : `mindset_engine` , `market_context_engine` , `technical_summary_engine` , `analysis_analytics` , dan mode Pemula/Pro yang benar-benar mengubah cara informasi disajikan. Itu semua logika murni yang berjalan di device, tercakup test dengan baik, dan berpihak pada edukasi ketimbang sinyal. Delapan disclaimer berbeda di ARB menunjukkan lo sadar posisi hukum dan etisnya. **Ini positioning lo: bukan "AI yang kasih sinyal", tapi "AI yang bikin trader pemula ngerti kenapa"**. Setiap keputusan produk ke depan sebaiknya diuji terhadap kalimat itu.

Roadmap 30 / 60 / 90 hari

JENDELA	FOKUS	ITEM
0–30 hari Tutup risiko	Keamanan & kesiapan store	P0-1 sampai P0-4 (semuanya). Lalu P1-5 (Sentry) dan P1-6 (CI) — dua ini mengubah cara lo bekerja, makin cepat dipasang makin banyak untungnya. Tutup dengan P1-9 ronde 1 & 2 dan P1-11.
30–60 hari Tutup janji	Notifikasi & kepercayaan	P1-10: putuskan nasib push. Kalau ya, kerjakan bareng P2-17 (go_router) karena keduanya saling terkait. Bareng itu, bereskan P1-7 (I10n) supaya user EN dapat pengalaman utuh, dan P1-8 supaya app terbuka instan saat cold start.
60–90 hari Perkuat fondasi	Skala & polish	P2-13 (pecah file besar), P2-14 (smoke test per tab), P2-12/P2-18 (adaptive icon & aksesibilitas), P2-20 (offline). Ini pekerjaan yang bikin fitur ke-20 sampai ke-40 tetap enak dibangun.

Empat gagasan produk yang codebase-nya sudah siap

1 • Notifikasi outcome, bukan sekadar price alert. App sudah melacak `outcomeStatus` (TP1 hit, TP2 hit, SL hit, expired, invalidated) dan sudah mem-polling-nya. Begitu push jalan, notifikasi paling bernilai bukan "XAU/USD menyentuh 2650" — tapi "*Analisis lo 3 hari lalu di XAU/USD kena TP1. Skenario utamanya benar.*" Itu momen yang bikin user percaya produknya dan buka app lagi. Datanya sudah ada; tinggal kanal pengirimannya.

2 • Rapor mingguan dari mesin yang sudah lo punya. `analysis_analytics` , `history_statistics` , dan `mindset_engine` sudah menghitung nyaris semua yang dibutuhkan. Satu layar ringkasan mingguan — berapa analisis, akurasi skenario, instrumen paling sering, dan satu insight mindset — memberi alasan untuk kembali setiap Senin. Ini jenis retensi yang tidak perlu fitur baru, cuma perlu penyajian baru.

3 • Kuota sebagai jalur monetisasi yang sudah setengah jadi. `AnalysisQuota` dengan `unlimited` , batas per jam dan per hari, sudah ada di API dan sudah ditampilkan di dashboard. Kerangka free-vs-paid praktis sudah berdiri. Kalau monetisasi masuk roadmap, jalannya pendek: tambahkan `in_app_purchase` , sambungkan status langganan ke kuota, dan sisipkan paywall di titik user membentur limit — momen di mana niat belinya paling tinggi. Yang perlu dipikir matang justru di luar kode: Apple dan Google memungut 15–30%, dan kebijakan mereka soal app finansial melarang menjanjikan hasil investasi. Posisi edukatif lo sudah aman di situ.

4 • Widget home screen. Untuk app trading, widget adalah fitur retensi dengan rasio dampak-per-usaha tertinggi: satu instrumen watchlist plus status analisis terakhir, terlihat tanpa membuka app. `home_widget` di Flutter membuat ini pekerjaan beberapa hari, bukan beberapa minggu, dan `WatchlistProvider` serta `MarketRepository` sudah menyediakan datanya.

Dua hal yang sebaiknya lo jangan lakukan

Jangan ganti Provider ke Riverpod/BLoC sekarang. Godaan itu akan datang. Tapi state management lo sudah menyelesaikan masalah-masalah sulit dengan benar — isolasi sesi, pembatalan request, race condition pagination. Migrasi berarti menulis ulang semua itu dan berisiko memperkenalkan bug di area yang saat ini justru paling kokoh. Provider tidak akan jadi hambatan lo dalam 12 bulan ke depan.

Jangan menambah fitur besar sebelum P0 beres. App ini sudah punya lebih banyak fitur daripada yang bisa didukung oleh infrastruktur operasionalnya. Tanpa crash reporting dan CI, setiap fitur baru menambah permukaan yang tidak bisa lo lihat kalau rusak.

Penutup

Buat sebuah app yang dibangun dalam waktu relatif singkat — 15 commit dari scaffold sampai rilis store — kualitasnya di atas ekspektasi. Yang lo hadapi sekarang bukan utang teknis dari kode yang buruk, tapi **jarak antara kode yang matang dan operasi yang belum menyusul**. Itu jarak yang jauh lebih mudah ditutup, dan urutannya sudah ada di halaman-halaman sebelumnya.

Lampiran • Data mentah audit

Perintah yang dijalankan

<code>flutter analyze</code>	0 issue
<code>flutter test</code>	151 lulus
<code>flutter test --coverage</code>	47,9%
<code>flutter pub outdated</code>	5 direct
Audit secret di Git	bersih

Ukuran codebase

File Dart (lib/)	77
Baris Dart (lib/)	26.909
File test	44
API client ter-vendor	281 file · 2,1 MB
Key localization	355 × 2 bahasa
Endpoint API tersedia	16 grup

Ringkasan temuan

P0 — Kritis	4
P1 — Penting	8
P2 — Kualitas	9
Total	21

Catatan verifikasi keamanan

Hal-hal berikut **diperiksa dan aman**, disebut di sini supaya lo tidak perlu mengeceknya lagi:

- `android/key.properties` dan `upload-keystore.jks` ada di disk tapi **tidak ter-track Git** — `android/.gitignore` sudah menutupnya dengan benar.
- Tidak ada API key, token, atau kredensial yang ter-commit di seluruh riwayat file yang ter-track.
- Base URL memakai HTTPS, dapat di-override lewat `--dart-define`, dan tidak ada `usesCleartextTraffic` di manifest.
- Token dikirim lewat interceptor yang tidak menimpa header `Authorization` yang sudah ada — implementasinya benar.
- Fitur hapus akun sudah ada (syarat Play Store & App Store), dan link kebijakan privasi, syarat layanan, serta dukungan sudah tersedia di layar profil.

Audit dilakukan pada commit `8c43038`, branch `feat/flutter-app`, 6 September 2026. Setiap nomor baris merujuk ke kondisi kode pada commit tersebut. Report disusun oleh Claude Opus 5 melalui Claude Code.